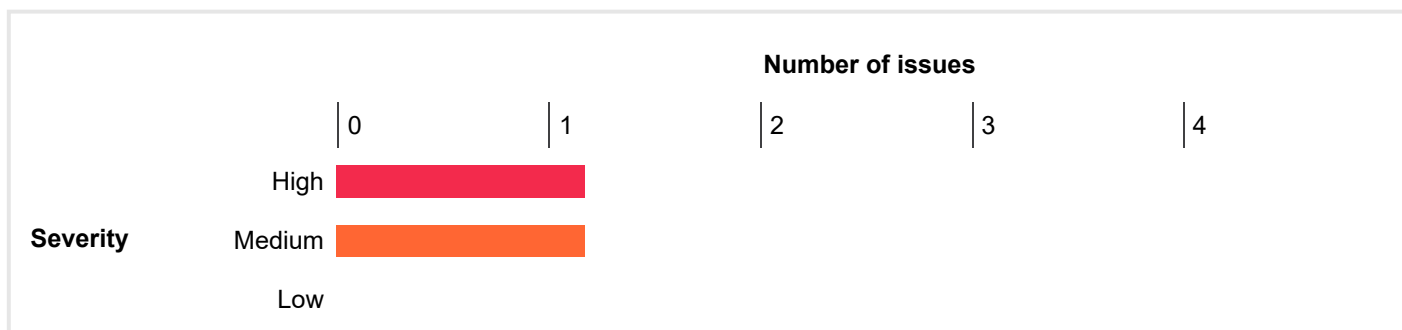


Summary

The table below shows the numbers of issues identified in different categories. Issues are classified according to severity as High, Medium, Low, Information or False Positive. This reflects the likely impact of each issue for a typical organization. Issues are also classified according to confidence as Certain, Firm or Tentative. This reflects the inherent reliability of the technique that was used to identify the issue.

		Confidence			Total
		Certain	Firm	Tentative	
Severity	High	1	0	0	1
	Medium	1	0	0	1
	Low	0	0	0	0
	Information	0	0	0	0
	False Positive	0	0	0	0

The chart below shows the aggregated numbers of issues identified in each category. Solid colored bars represent issues with a confidence level of Certain, and the bars fade as the confidence level falls.



Contents

1. Cross-origin resource sharing: arbitrary origin trusted

2. TLS certificate

1. Cross-origin resource sharing: arbitrary origin trusted

Summary

Severity: **High**
Confidence: **Certain**
Host: **https://www.pfizer.com**
Path: **/cdn-cgi/rum**

Issue detail

The application implements an HTML5 cross-origin resource sharing (CORS) policy for this request that allows access from any domain.

The application allowed access from the requested origin **https://rmwolinttukg.com**

Issue background

An HTML5 cross-origin resource sharing (CORS) policy controls whether and how content running on other domains can perform two-way interaction with the domain that publishes the policy. The policy is fine-grained and can apply access controls per-request based on the URL and other features of the request.

Trusting arbitrary origins effectively disables the same-origin policy, allowing two-way interaction by third-party web sites. Unless the response consists only of unprotected public content, this policy is likely to present a security risk.

If the site specifies the header Access-Control-Allow-Credentials: true, third-party sites may be able to carry out privileged actions and retrieve sensitive information. Even if it does not, attackers may be able to bypass any IP-based access controls by proxying through users' browsers.

Issue remediation

Rather than using a wildcard or programmatically verifying supplied origins, use a whitelist of trusted domains.

References

- [Web Security Academy: Cross-origin resource sharing \(CORS\)](#)
- [Exploiting CORS Misconfigurations](#)

Vulnerability classifications

- [CWE-942: Overly Permissive Cross-domain Whitelist](#)

Request

```
POST /cdn-cgi/rum? HTTP/2
Host: www.pfizer.com
Cache-Control: max-age=0
Sec-CH-UA: "Chromium";v="145", "Not;A=Brand";v="24", "Google Chrome";v="145"
Sec-CH-UA-Mobile: ?0
Sec-CH-UA-Platform: "Windows"
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
Accept: */*
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: close
Cookie: __cf_bm=A0Ytt_TsgPZlbdklJG.Zpq1VCliAfdRyZw.VjSAVN.4-1783179056.0659013-1.0.1.1-IO1q98Gu.zOeuMB4d2TDGi_OWko27fyEYXzUEWwJW_ygfDQ3Qb9o01hwGiRIAk8mx1.x7yfvUXgGUh63Dh.dnuQ5Egugv0hzy3ijpEUiW1w1aFipt1YaoSJ4GNgRkYgk; _gcl_au=1.1.526448466.1783179082; AMCVS_2FE3252C54CC13CC0A4C98A7%40AdobeOrg=1; s_ppn=404%20ErrorPage; AMCV_2FE3252C54CC13CC0A4C98A7%40AdobeOrg=179643557%7CMCIDTS%7C20639%7CMCMID%7C91169795250426543092439843453811631032%7CMCAAMLH-1783783883%7C12%7CMCAAMB-1783783883%7C6G1ynYcLPuiQxYZrsz_pkqfLG9yMXBpb2zX5dvJdYQJzPXImdj0y%7CMCOPTOUT-1783186283s%7CONE%7CMCSYNCSOP%7C411-20646%7CvVersion%7C5.5.0; s_nr=1783179089757-New;
```

s_sq=%5B%5BB%5D%5D;
s_sess=%20s_plt%3D1.42%3B%20s_pltp%3D404%2520ErrorPage%3B%20s_tp%3D1109%3B%20s_cc%3Dtrue%3B%20s_ppv%3D404%252520ErrorPage%252C97%252C97%252C1080%3B;
OptanonConsent=isGpcEnabled=0×tamp=Sat+Jul+04+2026+21%3A01%3A29+GMT%2B0530+(India+Standard+Time)&version=202605.1.0&browserGpcFlag=0&isDntEnabled=0&isIABGlobal=false&hosts=&consentId=b8a67ac9-fc95-45c7-acbf-6bde0bb06680&interactionCount=1&isAnonUser=1&prevHadToken=0&landingPath=https%3A%2F%2Fwww.pfizer.com%2FREADME.txt%2F&groups=BG478%3A1%2CC0001%3A1%2CBG479%3A0%2CC0004%3A0%2CBG480%3A0%2CC0002%3A0;
AWSALB=M3vz9hOLJMyRc/yG0xj4ADkWkArqPbyeCmq704Hc4Wcicx4BwJWu2WjLTd7r6opr5y+liaHF+JbVTjXgUX3sJu+BnBdcLUYXzzUWFPpt8sRTQQHESsBQsn7UB9c;
AWSALBCORS=M3vz9hOLJMyRc/yG0xj4ADkWkArqPbyeCmq704Hc4Wcicx4BwJWu2WjLTd7r6opr5y+liaHF+JbVTjXgUX3sJu+BnBdcLUYXzzUWFPpt8sRTQQHESsBQsn7UB9c;
_cfuvid=xUEK6sprDjAJHLK4Q.Pt0PxCW7Y0WI61COWoEnKleQ-1783179066.1072602-1.0.1.1-jKpuhMTKeYnPIPHh87gRcUqNaPzIq4DybSrLTUrCV3c
Origin: https://rmwolinttukg.com
Referer: https://www.pfizer.com/README.txt/
Content-Type: application/json
Content-Length: 1083

{ "referrer": "", "eventType": 3, "versions": { "js": "2026.6.0", "fl": "2024.11.0" }, "pageloadId": "1df0f1f4-ec2f-44a9-ba27-467185f923f7", "location": "https://www.pfizer.com/README.txt/", "landingPath": "/README.tx
...[SNIP]...

Response

HTTP/2 204 No Content
Date: Sat, 04 Jul 2026 15:32:22 GMT
Content-Type: text/plain
Access-Control-Allow-Origin: https://rmwolinttukg.com
Access-Control-Allow-Methods: POST,OPTIONS
Access-Control-Max-Age: 86400
Vary: Origin
Access-Control-Allow-Credentials: true
Server: cloudflare
Cf-Ray: a15f2ea7eb890bc9-BLR

2. TLS certificate

Summary

Severity: Medium
Confidence: Certain
Host: https://www.pfizer.com
Path: /

Issue detail

The following problem was identified with the server's TLS certificate:

- The server's certificate is not trusted.

Note: Burp relies on the Java trust store to determine whether certificates are trusted. The Java trust store does not include every root CA certificate that is included within browser trust stores. Burp might incorrectly report that a certificate is not trusted, if a valid root CA certificate is being used that is not included in the Java trust store.

The server presented the following certificates:

Server certificate

Issued to: www.pfizer.com
Issued by: WE1
Valid from: Sat Jun 06 02:17:57 IST 2026
Valid to: Fri Sep 04 03:17:39 IST 2026

Certificate chain #1

Issued to: WE1
Issued by: GTS Root R4
Valid from: Wed Dec 13 14:30:00 IST 2023
Valid to: Tue Feb 20 19:30:00 IST 2029

Certificate chain #2

Issued to: GTS Root R4
Issued by: GlobalSign Root CA
Valid from: Wed Nov 15 09:13:21 IST 2023
Valid to: Fri Jan 28 05:30:42 IST 2028

Issue background

TLS (or SSL) helps to protect the confidentiality and integrity of information in transit between the browser and server, and to provide authentication of the server's identity. To serve this purpose, the server must present an TLS certificate that is valid for the server's hostname, is issued by a trusted authority and is valid for the current date. If any one of these requirements is not met, TLS connections to the server will not provide the full protection for which TLS is designed.

It should be noted that various attacks exist against TLS in general, and in the context of HTTPS web connections in particular. It may be possible for a determined and suitably-positioned attacker to compromise TLS connections without user detection even when a valid TLS certificate is used.

References

- [SSL/TLS Configuration Guide](#)

Vulnerability classifications

- [CWE-295: Improper Certificate Validation](#)
- [CWE-326: Inadequate Encryption Strength](#)
- [CWE-327: Use of a Broken or Risky Cryptographic Algorithm](#)

Report generated by Burp Suite [web vulnerability scanner](#) v2026.2.3, at Sat Jul 04 23:00:42 IST 2026.